TECHRISE 3.0

Cybersecurity & DevSecOps Programme · Abia Cohort 3.0 · 2026

PHASE 1 · FOUNDATION & RED TEAM

WEEK 02

Cybersecurity Domains, Threat Landscape, Risk Assessment

Student Training Manual — AI-First Curriculum

PROGRAMME	COHORT	WEEK	PHASE
Cybersecurity & DevSecOps	Abia Cohort 3.0	2 of 12	1 — Foundation & Red Team

Methodology: AI-First (Manual → AI Enhancement)

Prepared by the TechRise Curriculum Design Team

Lead: Engr. Eduwem Adam · Co-facilitator: Mr. Akorita-Ifeanyichukwu Nehemiah

TABLE OF CONTENTS

- **Week 2: Cybersecurity Domains, Threat Landscape, and Risk Assessment**
  - Phase: Foundation (Weeks 1–4)
  - Day 1 — Cybersecurity Domains, OSI Model, and Career Paths
    - LEARN · PRACTICE · BUILD · DOCUMENT
  - Day 2 — Threat Landscape, Attack Vectors, and OWASP Top 10
    - LEARN · PRACTICE · BUILD · DOCUMENT
  - Day 3 — Risk Assessment Frameworks (NIST, ISO 27001, STRIDE)
    - LEARN · PRACTICE · BUILD · DOCUMENT
  - Day 4 — AI for Automated Risk Scoring and Threat Modelling
    - LEARN · PRACTICE · BUILD · DOCUMENT
  - Day 5 — Review, Assessment & Portfolio (Mini Project 1 Kickoff)
    - LEARN · PRACTICE · BUILD · DOCUMENT
- **Weekly Checklist (Student-Facing)**
- **Skills Verification**
- **Self-Assessment Quiz**
- **Additional Resources**
- **Looking Ahead — Week 3**

Phase: Foundation (Weeks 1–4) **Week 2 of 12**

WEEK 2: CYBERSECURITY DOMAINS, THREAT LANDSCAPE, AND RISK ASSESSMENT

Weekly Overview

This week transforms you from someone who knows what cybersecurity is into someone who understands the battlefield. You will learn the OSI model (how data actually travels), the OWASP Top 10 (the most critical web vulnerabilities), risk assessment frameworks (how companies decide what to protect), and how threat actors think. You will apply everything from Week 1 — your Linux commands, your networking knowledge, your understanding of permissions — to real security analysis work.

How this week builds on Week 1

- Last week you learned the CIA Triad and Linux fundamentals. This week you learn where attacks happen (OSI layers), what attackers target (OWASP Top 10), and how to measure risk (NIST, ISO 27001).
- Your Week 1 ss -tuln skills become vulnerability identification. Your dig skills become DNS attack surface mapping.

How this week sets up Week 3

- Week 3 is log analysis and scripting. You cannot analyse logs without understanding what normal traffic looks like (OSI model) and what attacks leave traces (OWASP). This week builds the detection mindset.

Why this matters in a real security job

- When a client asks 'What is our biggest risk?' you cannot answer with a port number. You must translate technical findings into business risk. This week teaches that translation.
- Security professionals who cannot speak risk stay junior forever.

DAY 1

Cybersecurity Domains, OSI Model, and Career Paths

LEARN *(1 Hour)*

LEARNING OBJECTIVES

1. Identify the seven layers of the OSI model and map common protocols to each layer

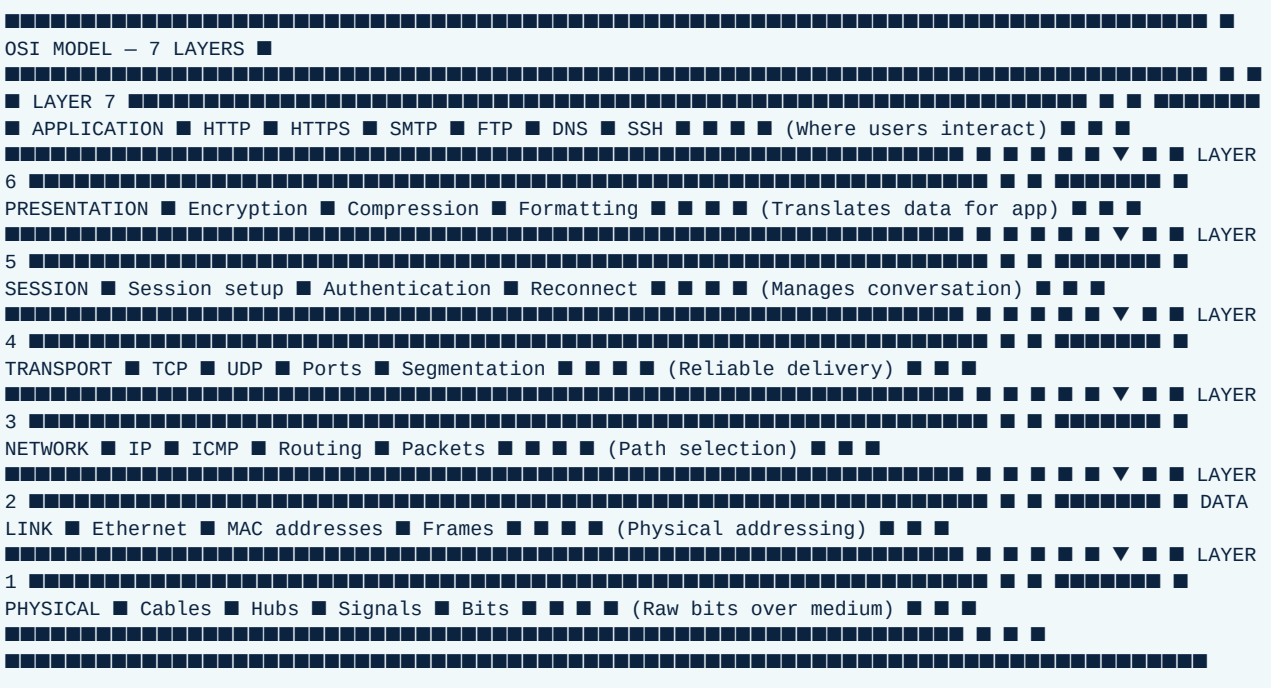
2. Distinguish between red team, blue team, and purple team roles

3. Explain how AI is transforming each cybersecurity domain

THE OSI MODEL (OPEN SYSTEMS INTERCONNECTION)

is a conceptual framework that divides network communication into seven layers, from physical cables up to application software, allowing different systems to communicate regardless of their internal architecture.

OSI Model — Full 7 Layers with Protocols



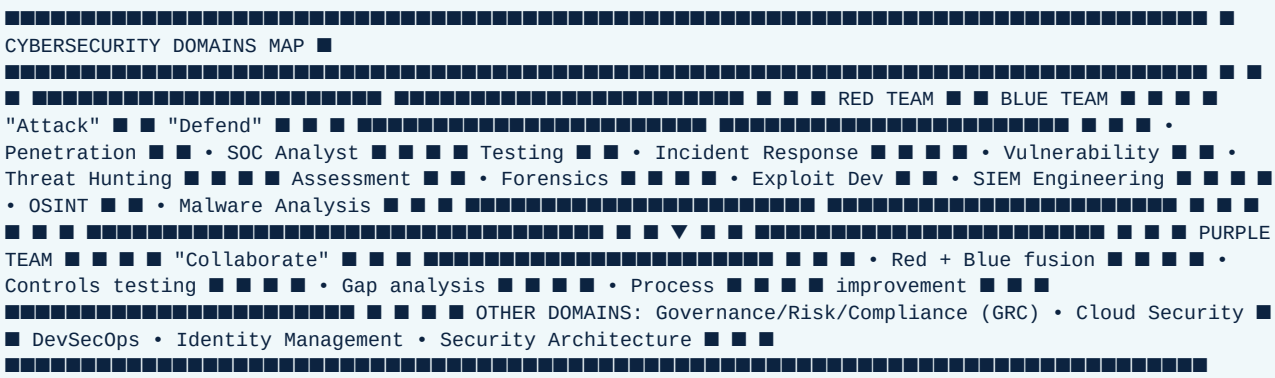
Where Attackers Operate (Layer by Layer)

Layer	Attacker Techniques	Security Controls
7 — Application	SQL injection, XSS, parameter tampering	WAF, input validation

6 — Presentation	SSL stripping, format string attacks	TLS 1.3, certificate pinning
5 — Session	Session hijacking, replay attacks	Tokens, timeouts, MFA
4 — Transport	Port scanning, SYN flood, DDoS	Firewall, rate limiting
3 — Network	IP spoofing, routing attacks, ping sweep	ACLs, IPSec, ingress filtering
2 — Data Link	ARP poisoning, MAC flooding, VLAN hopping	Port security, 802.1X
1 — Physical	Cable tapping, device theft, RFID cloning	Locks, cameras, access control

Cybersecurity Domains and Career Paths

Cybersecurity Domains Map



RED TEAM attacks systems with permission to find vulnerabilities. **Blue Team** defends against attacks and responds to incidents. **Purple Team** combines both to improve detection and prevention.

Certifications Roadmap

Level	Certification	Focus	Cost (USD)	Time to Prepare
Entry	CompTIA Security+	Foundational	$400	2–3 months
Technical	CEH (Certified Ethical Hacker)	Attack tools	$1,200	3–4 months
Advanced	OSCP (Offensive Security)	Hands-on hacking	$1,600	6+ months
Blue Team	CySA+	Detection, response	$400	2–3 months
Cloud	CCSK / AWS Security	Cloud specific	$400–600	1–2 months

AI in Cybersecurity — Current Applications

- SOC Automation: AI triages alerts, reduces false positives by 60–80%
- Threat Intelligence: AI processes millions of threat reports to identify patterns
- Malware Analysis: AI classifies unknown binaries by behaviour
- Phishing Detection: AI analyses email content and links in milliseconds
- User Behaviour Analytics: AI builds baselines and detects anomalies

WHY THIS MATTERS

The 2021 Colonial Pipeline ransomware attack succeeded because attackers penetrated the OT (Operational Technology) network after gaining access through a legacy VPN account. Understanding the OSI model and network layers helps defenders understand where controls failed — Layer 3/4 segmentation would have contained the attack.

PRACTICE *(2 Hours)*

LAB 2.1.1 — Layer 3 Discovery — Map Your Network

Objective: Discover all devices on your local network using ICMP (Layer 3).

Prerequisites: Terminal open, know your subnet

Step 1 — Find Your Subnet

BASH

```
ip a | grep -A 2 eth0
```

Expected output:

```
2: eth0: mtu 1500 inet 192.168.122.100/24 brd 192.168.122.255 scope global eth0
```

What this tells you: Your network is 192.168.122.0/24. The /24 means 254 possible hosts (1–254). Your IP is .100.

Step 2 — Ping Sweep to Find Live Hosts (Manual)

Try a few common addresses:

BASH

```
ping -c 1 192.168.122.1 # Gateway ping -c 1 192.168.122.2 # First host ping -c 1 192.168.122.254 # Last host
```

What this tells you: If you get a reply, the host is alive at Layer 3. No reply means either the host is down or ICMP is blocked (both are possible).

■ ANALYSE THIS

Why might a live host not respond to ping? Name two security reasons a network administrator might block ICMP responses.

Step 3 — Map OSI Layers to Running Services

BASH

```
ss -tuln # Layer 4 — what ports/services are listening ip route # Layer 3 — routing table ip neigh # Layer 2 — ARP table (MAC addresses)
```

What this tells you: Three commands, three OSI layers of information. ip neigh shows the ARP cache — the mapping of IP addresses to MAC addresses on your local segment.

■ ANALYSE THIS

Look at your ARP table output from ip neigh. If you see an IP address with a MAC you don't recognise, what OSI layer attack might this indicate?

BUILD *(2 Hours)*

BUILD BRIEF

Create an OSI Model Attack Surface Map — a professional reference document that maps every OSI layer to: protocols, attack types, and defensive controls.

Audience:

- A junior security analyst on their first day. Must be immediately useful.

Required content for each of the 7 layers:

- Layer number and name
- 2–3 protocols that operate here
- 2 realistic attack scenarios
- 2 defensive controls that address those attacks
- 1 real-world breach example that involved this layer

Format:

- Table — one row per layer, columns as above.

Quality standard:

- Every cell filled with specific, accurate content. No generic placeholder text.

DOCUMENT *(1 Hour)*

DOCUMENT

Writing Prompt:

Write a professional briefing note titled 'Understanding the OSI Model for Security Decision-Making.' Audience: IT Manager with networking background but no security specialisation. Length: 250–300 words.

- Required structure: Executive Summary (2 sentences) / The 7 Layers Explained (one line per layer) / Where Attackers Focus (top 3 layers by frequency) / Recommended First Controls (3 specific actions)
- Tone: Professional, concise, actionable. Avoid jargon without explanation.

DAY 2

Threat Landscape, Attack Vectors, and OWASP Top 10

LEARN *(1 Hour)*

LEARNING OBJECTIVES

1. Classify malware types and explain how each evades detection

2. Map the OWASP Top 10 (2021) to real attack scenarios

3. Analyse a CVE entry and extract actionable security information

THE OWASP TOP 10

is an annually updated list of the most critical web application security risks, compiled from data contributed by hundreds of security organisations worldwide. It is the global standard reference for web security.

OWASP Top 10 (2021) — Complete Reference

Rank	Vulnerability	Description	Example Attack
A01	Broken Access Control	Users access data/functions beyond their permissions	Change /profile/123 to /profile/124 and view another user's data
A02	Cryptographic Failures	Sensitive data exposed due to weak/missing encryption	HTTP (not HTTPS) transmitting passwords; MD5 hashed passwords
A03	Injection	Attacker injects code into interpreter as part of a query	' OR '1'='1 in login field bypasses authentication
A04	Insecure Design	Missing or ineffective security controls in architecture	No rate limiting on login — allows unlimited brute force
A05	Security Misconfiguration	Insecure default settings, unnecessary features enabled	Default admin/admin credentials on network device
A06	Vulnerable Components	Using libraries/frameworks with known vulnerabilities	Log4Shell (CVE-2021-44228) — RCE via logging library
A07	Auth Failures	Broken authentication allows account takeover	No lockout after failed logins; weak session tokens
A08	Data Integrity Failures	Untrusted data used without verification	Malicious update package — no signature verification
A09	Logging/Monitoring Failures	Insufficient logging means attacks go undetected	Attacker exfiltrates data over weeks; no alerts fired
A10	SSRF	Server makes requests to attacker-controlled URLs	Server fetches http://169.254.169.254 — leaks AWS credentials

Malware Types — Classification and Detection Evasion

Type	Behaviour	Detection Evasion	Real Example
Virus	Attaches to legitimate files; activates when file runs	Polymorphic code changes signature each generation	CIH/Chernobyl (1998) — destroyed BIOS
Worm	Self-replicates across network without user action	Exploits 0-days before patches; propagates at speed	WannaCry (2017) — 200,000 machines in 3 days
Trojan	Appears legitimate; hides malicious payload	Code signing, legitimate-looking installers	Emotet — disguised as invoice emails
Ransomware	Encrypts files; demands payment for decryption key	Legitimate encryption APIs; deletes volume shadow copies	Colonial Pipeline (2021) — $4.4M paid
Rootkit	Hides malware at OS/kernel level	Patches system calls to hide from ls, ps, netstat	Stuxnet — hid from SCADA monitoring systems
Spyware	Silently collects and transmits data to attacker	Low resource usage; disguised as legitimate apps	Pegasus — zero-click iPhone exploit

CVE (Common Vulnerabilities and Exposures) — How to Read One

Every known vulnerability gets a CVE number: CVE-YEAR-NUMBER (e.g. CVE-2021-44228 = Log4Shell)

CVE Entry Structure — Log4Shell Example

```
CVE-2021-44228 | CVSS Score: 10.0 CRITICAL
■■■
```

Extract and record: CVSS Score, Attack Vector, Privileges Required, User Interaction, Scope, Confidentiality/Integrity/Availability impact

Step 2 — Classify the Threat

Using today's OWASP Top 10 table, identify which OWASP category Log4Shell falls under. Justify your answer in two sentences.

Step 3 — AI-Assisted CVE Analysis

PROMPT

```
I am a cybersecurity student. Explain CVE-2021-44228 (Log4Shell) to me as if I am presenting it to a non-technical IT manager. Include: what it is, why it is critical, what systems are affected, and what the fix is. Keep it under 150 words.
```

Compare the AI response to what you read on NVD. Note: what did AI get right? What was missing or inaccurate? Save your analysis to threat_research_log.txt.

LAB 2.2.2 — OWASP Injection Demo — SQLi on DVWA

Objective: Demonstrate SQL injection on a deliberately vulnerable application.

Prerequisites: DVWA running (docker run -d -p 80:80 vulnerables/web-dvwa)

■ Authorisation Reminder

DVWA is a deliberately vulnerable application designed for learning. Only perform these tests on DVWA running locally on your own machine. SQL injection on any other system without explicit written authorisation is illegal under Nigeria's Cybercrimes Act 2015.

Step 1 — Access DVWA

Open browser → http://localhost/login.php → Login: admin / Password: password → Set Security Level to Low

Step 2 — Test Basic SQL Injection

Navigate to SQL Injection → Enter in the User ID field:

SQL

```
1' OR '1'='1
```

What this tells you: If all user records appear, the input is not sanitised. The database is executing your SQL code. This is OWASP A03 — Injection.

Step 3 — Extract Database Information

SQL

```
1' UNION SELECT user(), database()--
```

What this tells you: The UNION statement appends your query to the original. user() returns the database user running the query. database() returns the current database name. An attacker now knows what permissions the DB user has.

■ ANALYSE THIS

The database user returned was 'root@localhost'. Why is this catastrophic from a security perspective? What should the database user have been, and what OWASP principle does this violate?

BUILD *(2 Hours)*

BUILD BRIEF

Create a Threat Intelligence Brief on one real-world malware family. Choose one: WannaCry, Emotet, Mirai, or Pegasus.

Required sections:

- Overview — What is it? When was it discovered? Who created it?
- Attack Vector — How does it spread? Which OSI layer does it primarily exploit?
- OWASP Mapping — Which OWASP Top 10 category does the initial infection vector fall under?
- CVE Reference — Find the primary CVE associated with it and include CVSS score
- CIA Triad Impact — How did it affect Confidentiality, Integrity, and Availability?
- Detection Indicators — 3 specific indicators of compromise (IoCs) to look for
- Remediation — 3 specific preventive measures

Format:

- Professional report, 400–500 words. Include a brief timeline of events.

AI use:

- You may use AI for research assistance but must validate every fact against a primary source (NVD, vendor advisory, or news report). Document your validation.

DOCUMENT *(1 Hour)*

DOCUMENT

Writing Prompt:

Write a Security Advisory email to all staff at a fictional company explaining the risk of phishing emails (social engineering). The company was recently targeted but not breached. Audience: non-technical staff. Length: 200–250 words.

- Required: Specific description of what phishing looks like (3 examples), what to do if you receive a suspicious email (3 actions), who to report to, and one real breach caused by phishing
- Tone: Urgent but not alarmist. Clear and simple — no jargon.
- FROM: IT Security Team / TO: All Staff / SUBJECT: [Action Required] Phishing Attempt Detected — Read Before Opening Emails

DAY 3

Risk Assessment Frameworks (NIST, ISO 27001, STRIDE)

LEARN *(1 Hour)*

LEARNING OBJECTIVES

1. Explain the NIST Cybersecurity Framework 2.0 functions and their relationship

2. Perform a basic risk assessment using the likelihood × impact matrix

3. Apply STRIDE threat modelling to a simple web application

RISK ASSESSMENT

is the process of identifying potential threats to an organisation, evaluating the likelihood they will occur, estimating the impact if they do, and prioritising responses accordingly. It is the foundation of all security decision-making.

NIST Cybersecurity Framework (CSF) 2.0 — The Six Functions

Function	What It Means	Example Activities
GOVERN	Establish cybersecurity strategy, policies, roles	Write security policy; define risk appetite; assign CISO
IDENTIFY	Understand your assets, risks, and environment	Asset inventory; threat modelling; risk assessment
PROTECT	Implement safeguards to deliver critical services	MFA; encryption; access control; security awareness training
DETECT	Develop activities to identify cybersecurity events	IDS/IPS; SIEM; log monitoring; anomaly detection
RESPOND	Take action when a cybersecurity incident occurs	IR plan; communication; containment; eradication
RECOVER	Restore capabilities after a cybersecurity incident	Backup restoration; business continuity; lessons learned

Risk Assessment — Likelihood × Impact Matrix

Risk Rating Matrix

```
■■■
```

Step 1 — Asset Inventory

BASH

```
# List all running services systemctl list-units --type=service --state=running # List open ports
ss -tuln # List all users cut -d: -f1 /etc/passwd
```

Record each finding as an asset. Asset = anything that has value and could be targeted.

Step 2 — Threat Identification

For each open port/service found, identify: what threat actor would target it, how they would attack it, which OWASP category applies (if it's a web service).

Step 3 — Risk Rating

Apply the Likelihood × Impact matrix to each finding. Record your scores in a table with columns: Asset, Threat, Likelihood (1–3), Impact (1–3), Risk Score, Priority.

■ ANALYSE THIS

If you found SSH (port 22) open to 0.0.0.0 with default credentials, what risk score would you assign? Justify your Likelihood and Impact ratings separately.

BUILD *(2 Hours)*

BUILD BRIEF

Perform a STRIDE threat model on a fictional e-commerce checkout page and produce a professional threat modelling report.

Scenario:

- An e-commerce company is launching a new checkout feature. It takes: user account ID, cart items, delivery address, payment card number, and CVV.

Required:

- Data Flow Diagram — ASCII diagram showing: User → Browser → Web Server → Database → Payment Gateway
- STRIDE Analysis Table — one row per threat type, applied to the checkout feature specifically
- Top 3 Risks — ranked by Risk Score with specific mitigations
- NIST CSF Mapping — map each mitigation to a NIST CSF 2.0 function

Format:

- Professional security report, 500–600 words plus tables.

Quality standard:

- Every STRIDE row must have a specific attack scenario (not generic), a real-world example, and a concrete mitigation.

DOCUMENT *(1 Hour)*

DOCUMENT

Writing Prompt:

Write a Risk Treatment Recommendation memo for a fictional bank that has the following finding: 'SSH port 22 is open to the internet on 14 servers, 6 of which are running outdated OpenSSH versions with known CVEs.' Audience: CISO. Length: 250–300 words.

- Required: Risk rating with CVSS context, business impact if exploited, 3 specific remediation actions with timelines, NIST CSF 2.0 functions addressed by each action
- Format: TO: CISO / FROM: Security Analyst / DATE: [today] / SUBJECT: Critical Remediation Required — SSH Exposure on 14 Production Servers / Classification: CONFIDENTIAL

DAY 4

AI for Automated Risk Scoring and Threat Modelling

LEARN *(1 Hour)*

LEARNING OBJECTIVES

1. Design effective AI prompts for security research and risk analysis tasks

2. Critically evaluate AI-generated threat intelligence for accuracy and gaps

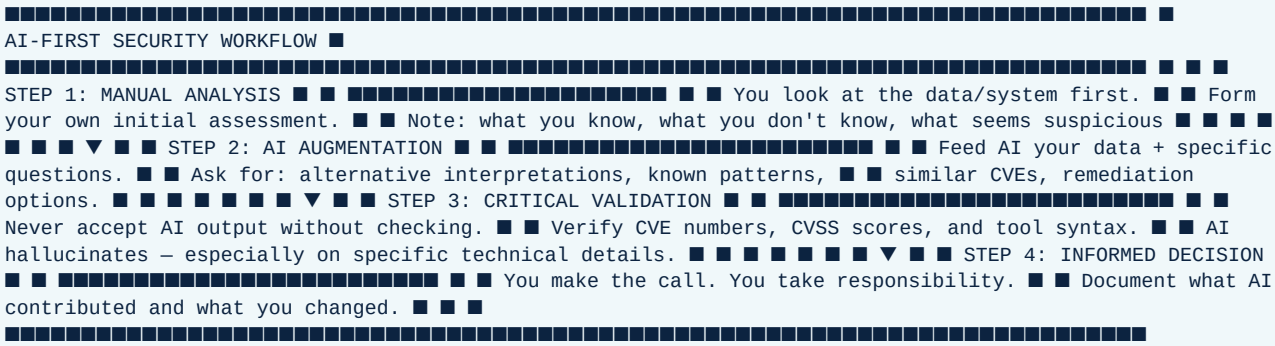
3. Use AI to accelerate STRIDE threat modelling without bypassing critical thinking

AI-FIRST IN CYBERSECURITY

means using AI as a force multiplier — it handles volume and initial triage so you can focus on judgement, creativity, and the work AI cannot do: understanding business context, making ethical decisions, and taking responsibility.

The AI-First Security Analyst Workflow

Manual → AI Enhancement Cycle



Security-Specific AI Prompt Engineering

Task	Poor Prompt	Effective Prompt
CVE Analysis	'Tell me about Log4Shell'	'I am a security analyst. Summarise CVE-2021-44228: affected versions, attack vector, CVSS score, and 3 specific mitigations. Flag anything you are uncertain about.'
STRIDE Modelling	'Do a threat model for my app'	'Apply STRIDE to a REST API endpoint that accepts user ID and returns account balance. For each threat type: describe the attack, rate likelihood (1–3), and suggest one mitigation.'

Risk Rating	'Is this risky?'	'Given: SSH port 22 open to internet, running OpenSSH 7.4, no MFA. Rate the risk using CVSS 3.1 criteria: Attack Vector, Complexity, Privileges Required, User Interaction, CIA impact. Provide a numerical score.'
Malware Analysis	'What is ransomware?'	'I found a file that creates a mutex named 'Global\MS_MCIMPEG' and connects to 45.61.x.x:443. What malware family does this match? What IoCs should I look for? Where can I verify this?'

AI Limitations in Security Contexts — Critical Awareness

- AI knowledge cutoff: AI models are trained on data up to a certain date. CVEs published after cutoff will be unknown to the model.
- AI hallucination: AI confidently states incorrect CVE numbers, wrong CVSS scores, and non-existent tools. Always verify on NVD or vendor advisories.
- AI cannot see your network: AI gives general advice. It cannot scan your system or know your specific configuration.
- AI ethics: Do NOT paste actual client data, real IP addresses, or real credentials into public AI tools. Use sanitised or fictional data for practice.
- AI output is not authoritative: In a professional report, you are responsible for every finding. 'AI told me' is not a valid citation.

■ **Pro Tip:** *Use AI to generate a first draft of any framework document (risk register, threat model, IR playbook), then review and correct it. This is faster than writing from scratch and teaches you what good output looks like — because you will spot the gaps.*

PRACTICE *(2 Hours)*

LAB 2.4.1 — AI-Assisted Threat Intelligence

Objective: Use AI to research, analyse, and validate threat intelligence data.

Prerequisites: AI assistant open, browser access to NVD and CVE databases

Step 1 — AI-Generated Risk Register

Give your AI assistant this exact prompt:

PROMPT

```
You are a cybersecurity analyst. I have a web application with the following characteristics:
Python Django backend, PostgreSQL database, hosted on AWS EC2, publicly accessible admin panel at
/admin/, no WAF, default Django debug mode enabled in production, last security update 18 months
ago. Generate a risk register with 5 specific risks. For each risk include: Risk ID, Description,
Threat Actor, OWASP Category, Likelihood (H/M/L), Impact (H/M/L), Risk Score, and Recommended
Mitigation. Format as a table.
```

After receiving the output: validate 2 of the 5 risks against OWASP documentation. Note any inaccuracies. Record what you changed and why.

Step 2 — AI STRIDE Analysis

Give your AI assistant this exact prompt:

PROMPT

```
Apply the STRIDE threat model to a file upload feature in a web application. The feature allows authenticated users to upload profile photos (max 5MB, JPG/PNG). The file is stored on S3 and a URL is saved in the database. For each STRIDE threat type: 1. Describe a specific attack scenario 2. Rate likelihood as High/Medium/Low with justification 3. Suggest a specific mitigation with implementation detail Flag any assumption you make about the architecture.
```

Review the AI output critically. Add one threat the AI missed. Document what the AI overlooked and why you identified it.

■ ANALYSE THIS

The AI suggested 'validate file type by checking the file extension.' Why is this insufficient? What is the correct technical approach and which OWASP category does file upload abuse fall under?

BUILD *(2 Hours)*

BUILD BRIEF

Create an AI-Assisted Security Research Playbook — a personal reference for how you will use AI tools throughout this 12-week course.

Section 1 — My AI Tool Stack:

- List 3 AI tools you will use, their strengths for security work, and their known limitations

Section 2 — Prompt Templates:

- Write 5 reusable prompt templates for: CVE analysis, STRIDE threat modelling, risk rating, malware classification, and log analysis

Section 3 — Validation Checklist:

- 10-step checklist you will follow every time you use AI output in a professional deliverable

Section 4 — Ethical Boundaries:

- 3 types of data you will never paste into a public AI tool, and why

Section 5 — AI vs Manual Decision Matrix:

- A table with 10 security tasks: which you will do manually first, which you will AI-assist, and which you will AI-generate and validate

Format:

- Personal reference document. Professional but practical — you will actually use this.

DOCUMENT *(1 Hour)*

DOCUMENT

Writing Prompt:

Write a one-page position paper titled 'Should AI Be Used in Cybersecurity Incident Response?' Argue both sides with evidence, then give your personal conclusion. Audience: Your future cybersecurity team. Length: 300–400 words.

- Required: 2 specific arguments FOR AI in IR (with examples), 2 specific arguments AGAINST or cautionary (with examples), your conclusion with reasoning
- You may use AI to generate a first draft, but you must significantly edit and add your own analysis. Document: what the AI wrote vs what you added.

DAY
5

Review, Assessment & Portfolio (Mini Project 1 Kickoff)

LEARN *(1 Hour) — Week Review*

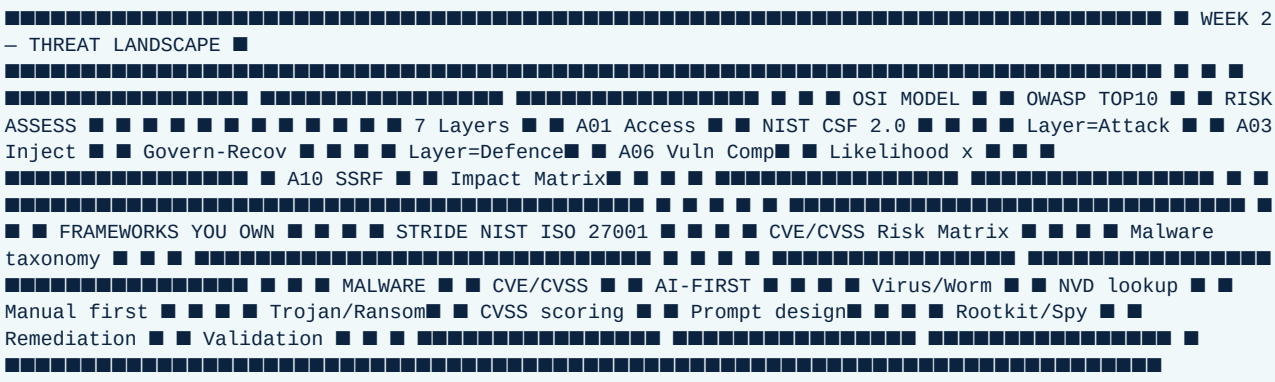
LEARNING OBJECTIVES

1. Recall and connect all major frameworks from Week 2 without referencing notes

2. Complete a skills assessment demonstrating threat analysis capability

3. Kick off Mini Project 1 with a clear scope, methodology, and timeline

Week 2 Mind Map — Threat Landscape



PRACTICE *(2 Hours) — Skills Assessment Labs*

LAB 2.5.1 — OSI Model Identification Challenge

Objective: Identify which OSI layer an attack targets without referencing notes.

Prerequisites: No notes — answer from memory

Identify the OSI layer for each scenario:

1. An attacker sends thousands of SYN packets to a web server, exhausting connection resources

2. A SQL injection payload is inserted into a login form

3. An attacker poisons the ARP cache to redirect traffic through their machine

4. A certificate is forged to perform a man-in-the-middle attack on HTTPS traffic

5. A physical cable tap is installed in a data centre

LAB 2.5.2 — Risk Scoring Under Pressure

Objective: Rate the following scenarios using the Likelihood × Impact matrix in 30 minutes.

Prerequisites: No notes

1. An e-commerce site has a public-facing database admin panel (phpMyAdmin) accessible with default credentials
2. A company's internal wiki has SQL injection but is only accessible from the office VPN
3. An executive's laptop has no screen lock timeout, but the executive works in a locked private office
4. A web application uses MD5 to hash passwords but has no known vulnerabilities in other areas

For each: Likelihood (1–3), Impact (1–3), Score, OWASP category, and one-sentence mitigation.

LAB 2.5.3 — AI-Validated STRIDE Exercise

Objective: Complete a STRIDE analysis manually, then use AI to critique and improve it.

Prerequisites: Terminal open; AI assistant in browser

Target: A password reset feature that: emails a reset link to the registered email, link expires after 24 hours, clicking the link shows a form to set a new password.

1. Complete the STRIDE table manually — all 6 threat types, without AI
2. Feed your STRIDE table to AI: 'Review this STRIDE analysis for a password reset feature. What threats did I miss? What mitigations could be strengthened?'
3. Document: what AI found that you missed, what you found that AI missed, and your final assessment of which source was more thorough

BUILD *(2 Hours) — Mini Project 1 Kickoff*

■ MINI PROJECT 1 — Security Assessment Report — Fictional Organisation

Produce a professional security assessment report for a fictional Nigerian fintech company. This is your first major portfolio piece — treat it like a real client deliverable.

Deliverables:

- Executive Summary (non-technical): 1 paragraph explaining the overall security posture and top 3 risks
- Asset Inventory: List 10 assets (servers, applications, data types) with classification (Public / Internal / Confidential / Secret)
- Threat Assessment: Identify 5 specific threats relevant to a Nigerian fintech (including insider threat and social engineering). Map each to: OSI layer + OWASP category + STRIDE category
- Risk Register: 5 risks with Likelihood, Impact, Score, and Priority
- Vulnerability Findings: 3 specific vulnerabilities with CVE references where applicable, CVSS scores, and evidence
- NIST CSF 2.0 Gap Analysis: Rate the fictional company against each of the 6 functions (1–5 scale) with justification

- Recommendations: 5 prioritised remediation actions with: effort (Low/Medium/High), impact (Low/Medium/High), and timeline (30/60/90 days)
- BONUS: Include a STRIDE diagram of their payment processing flow

Tools: All frameworks from Weeks 1–2 · NVD/CVE databases · AI tools (with validation) · OWASP Testing Guide

Mini Project 1 — Scope & Timeline

- Scope: Fictional company — 'PayliteNG', a Lagos-based mobile payment app
- Due: End of Week 3 (next week)
- Submission: PDF report + supporting evidence folder
- Evaluation: Accuracy of framework application, depth of analysis, professional report writing
- AI policy: Document all AI usage in an appendix. Fact-check every AI-generated finding.

DOCUMENT *(1 Hour) — Week Summary*

DOCUMENT

Writing Prompt:

Write a weekly learning reflection addressed to your Week 12 self. Length: 300–400 words.

- Three specific frameworks you can now apply without looking them up (with one example for each)
- The hardest concept from this week and how you worked through it
- One real-world news story from this week that connects to something you learned
- How you will use AI differently next week based on what you learned about its limitations
- A prediction: Which OWASP vulnerability do you think will appear in your Week 6 web application testing lab?

Weekly Checklist (Student-Facing)

- ■ I can name all 7 OSI layers and give one attack example per layer from memory
- ■ I can explain the difference between Red Team, Blue Team, and Purple Team roles
- ■ I can identify which OWASP category a described vulnerability belongs to
- ■ I have looked up at least 2 CVEs on NVD and extracted: CVSS score, attack vector, and fix
- ■ I have completed a STRIDE analysis on a web feature
- ■ I can apply the Likelihood × Impact matrix to produce a risk score
- ■ I have researched one real malware family and written a threat intelligence brief
- ■ I have used AI for at least one security research task and documented my validation steps
- ■ I have identified at least 2 cases where AI output was inaccurate or incomplete
- ■ My Mini Project 1 is scoped and I know what I am building by end of Week 3

Skills Verification

Skill	How to Demonstrate It	Pass Standard
OSI Layer Mapping	Given 5 attack scenarios, identify the correct OSI layer	4 out of 5 correct without referencing notes
OWASP Classification	Given a vulnerability description, name the OWASP Top 10 category	Correct category for 3 out of 3 scenarios
CVE Analysis	Open NVD, look up a CVE, and extract CVSS score + attack vector + fix	Accurate extraction within 5 minutes
Risk Scoring	Given 3 risks, apply Likelihood × Impact to produce ranked list	Scores justified with reasoning; ranking defensible
STRIDE Application	Apply all 6 STRIDE categories to a described feature	All 6 present; attack scenario specific to the feature
AI Validation	Show AI prompt + response + your validation notes	At least one correction or addition documented

Self-Assessment Quiz

Instructions

- Answer all questions without looking at notes.
- Write answers on a separate sheet.
- Key is in Instructor Notes.

Framework Questions

1. Name the six functions of the NIST Cybersecurity Framework 2.0 in order. For each, give one specific activity.
2. What does STRIDE stand for? For each letter, give a one-sentence definition and one example relevant to a mobile banking app.

Classification Questions

3. Classify each of the following into an OWASP Top 10 (2021) category:

- A user can access /api/account/998 by changing the account number in the URL
- A web app uses SHA1 to hash passwords (SHA1 is cryptographically broken)
- A server error returns: 'MySQL Error: Table users does not exist'
- A library used by the app has a known RCE vulnerability that has not been patched

Scenario Analysis

4. You are a security analyst. A client reports their website is displaying a competitor's homepage. Identify: which OSI layer the attack likely occurred at, what attack technique was used, which CIA pillar was violated, and the immediate remediation steps.
5. A Nigerian fintech receives a phishing email campaign targeting employees. Map this to: OWASP Top 10 category, STRIDE threat type, and NIST CSF 2.0 functions that should have prevented it.

CVE Analysis

6. Look up CVE-2017-5638 (Apache Struts — Equifax breach). Without AI assistance: identify the CVSS score, the attack vector, which OWASP category it falls under, and what specific remediation was required.

AI Critical Thinking

7. You ask an AI assistant: 'What are the 10 most dangerous CVEs of 2024?' The AI responds with a list of CVEs with descriptions. What are 3 specific things you must verify before using this output in a professional report?

Additional Resources

Official Frameworks & Standards

- NIST CSF 2.0 Full Framework: https://www.nist.gov/cyberframework
- OWASP Top 10 (2021): https://owasp.org/www-project-top-ten/
- NVD — National Vulnerability Database: https://nvd.nist.gov
- MITRE CVE List: https://cve.mitre.org

Free Labs & Practice

- DVWA — Damn Vulnerable Web Application: https://dvwa.co.uk
- TryHackMe — OWASP Top 10 Room (Free): https://tryhackme.com/room/owasptop10
- PortSwigger Web Security Academy (Free): https://portswigger.net/web-security

Threat Intelligence

- VirusTotal (malware analysis): https://www.virustotal.com
- Verizon DBIR 2023: https://www.verizon.com/business/resources/reports/dbir/
- MITRE ATT&CK; Framework: https://attack.mitre.org

Nigerian Context

- CBN Risk-Based Supervision Framework: https://www.cbn.gov.ng
- NDPC — Nigeria Data Protection Commission: https://ndpc.gov.ng
- CyberSafe Foundation Nigeria: https://cybersafefoundation.org

Looking Ahead — Week 3

Preview — What's Coming in Week 3

- Log Analysis & Bash Scripting — you will write scripts that automatically analyse system logs
- Python for Security Automation — automate the port scanning and permission checking from Week 1
- Your threat landscape knowledge (Week 2) becomes your detection logic — if you know what attacks look like, you know what to search for in logs
- Mini Project 1 is due — final sprint to complete your Security Assessment Report

What to Review Before Week 3

- The 10 critical ports — Week 3 logs are full of them
- ss -tuln and ip a — you will write a script that runs these automatically
- Your OWASP knowledge — log entries map directly to OWASP attack patterns

What to Install Before Week 3

- Ensure Python 3 is installed: python3 --version
- Install: pip3 install python-nmap requests
- Create a logs/ directory in your home folder for next week's lab files
- Complete Mini Project 1 — it is due at the start of Week 3